

Lido Vault Middleware Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Stalin

Immeas

December 19, 2025

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Lido on Lido Vault Middleware. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated December 19, 2025, was delivered to Lido, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Lido or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 5 days, the Cyfrin team conducted an audit on the Lido Vault Middleware code provided by Lido. The findings consist of 5 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Lido Vault Middleware
Repository	defi-interface
Commit	99fd2b2c64c3...
Fix Commit	fc15b104d385...
Audit Timeline	Dec 15th - Dec 19th, 2025
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	5	5	0
Informational	6	5	1
Gas Optimizations	2	2	0
Total	13	12	1

6 Audit Scope

The audit scope was limited to:

```
src/adapters/ERC4626Adapter.sol
src/EmergencyVault.sol
src/RewardDistributor.sol
src/Vault.sol
```

7 Risk Classification

	Impact: High	Impact: Medium	Impact: Low
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Lido Defi-interface provides an ERC4626-compliant middleware layer that wraps external ERC4626 vaults (e.g., Morpho strategies) and adds fee harvesting, reward distribution and an emergency withdrawal/recovery flow. The system is structured as a reusable `Vault` core and an `EmergencyVault` extension.

The Vault overrides all standard **preview functions** (e.g., `previewDeposit`). These functions simulate the pending fee harvest, so that the values displayed in user interfaces match the execution results, accounting for fee dilution.

The system uses a **High Water Mark** model with synchronous fee harvesting, so it does not rely on external keepers: any surplus value generated in the underlying protocol (e.g., share appreciation or airdrops) is recognized as profit and distributed as yield.

The vault has an *Emergency Mode*, which withdraws the remaining funds from the underlying vault, followed by a one-way transition to *Recovery Mode*. In Recovery Mode deposits are disabled and users exit via `redeem`, which distributes the recovered assets pro-rata among the remaining shareholders.

Key Components

1. `Vault` **(Base Layer):** handles standard ERC4626 accounting and performance fee harvesting.
2. `EmergencyVault`**:** extends the base vault with Emergency Mode and Recovery Mode (pro-rata distribution of recovered assets).
3. `ERC4626Adapter` **(Integration Layer):** a concrete implementation that forwards capital into target strategies (e.g., Aave, MetaMorpho).
4. `RewardDistributor`**:** a contract that redeems accumulated fee shares and distributes the assets to recipients based on fixed allocation percentages.

9 Attestation

Cyfrin attests that it performed a security review of the Lido Vault Middleware code provided by Lido.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-12-19-cyfrin-lido-earn-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Lido has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=5ebbc007f090b3cdd463c2d55291a6fd26b445299b31f7b3d876b5ee7a917c6f
F=2025-12-19-cyfrin-lido-earn-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.